
Fundamentals of Information Systems Security

Fourth Edition

Project 5

Compliance Audit Simulation

Student Name: _____

Student ID: _____

Instructor: Guuleed Maxamuud Aw Abdi

Date: _____

Weight: 20%

Submission Format: PDF Report via Course Platform

Contents

1	Project Overview	2
2	Learning Objectives	2
3	Scenario	2
4	Project Tasks	2
4.1	Task 1: Select and Understand the Framework	2
4.2	Task 2: Assess Current State	3
4.3	Task 3: Audit Findings	3
4.4	Task 4: Recommendations and Remediation Plan	3
4.5	Task 5: Final Audit Report	3
5	Deliverables	3
6	Evaluation Rubric	4
7	Submission Guidelines	4
8	Due Date and Late Policy	4
9	Resources	4

1 Project Overview

About This Project

In this project, you will simulate a compliance audit against a fictional organization. You will assess the organization's compliance with a selected regulatory framework (GDPR, HIPAA, PCI DSS, or SOX) and produce an audit report with findings, recommendations, and a remediation plan.

This project integrates knowledge from **Chapters 4, 8, and 9**, focusing on governance, auditing, and monitoring.

2 Learning Objectives

Upon completion of this project, you will be able to:

1. Understand the requirements of major compliance frameworks
2. Plan and conduct a compliance audit
3. Identify gaps between current practices and regulatory requirements
4. Prioritize findings based on risk and impact
5. Develop a remediation roadmap

3 Scenario

Organization Profile

You are a senior compliance auditor at **CompliancePro Services**. You have been assigned to conduct a compliance audit for **DataVault Solutions**, a cloud-based data storage company that handles customer data from EU citizens (GDPR), credit card information (PCI DSS), and healthcare data (HIPAA).

The organization has recently expanded and is concerned about meeting regulatory obligations. Your audit will assess their compliance posture and provide actionable recommendations.

4 Project Tasks

4.1 Task 1: Select and Understand the Framework

Task 1 Instructions

1. Choose one primary framework (GDPR, HIPAA, PCI DSS, or SOX)
2. Research the key requirements of the chosen framework
3. Identify which parts of the framework apply to DataVault Solutions

4.2 Task 2: Assess Current State

Task 2 Instructions

1. Review the provided documentation (policies, procedures, system descriptions)
2. Identify gaps between current practices and framework requirements
3. Conduct interviews (simulated) to gather additional information

4.3 Task 3: Audit Findings

Task 3 Instructions

Document each finding with:

- Description of the non-compliance
- Applicable framework requirement
- Risk level (High, Medium, Low)
- Evidence (screenshots, logs, interview notes)

4.4 Task 4: Recommendations and Remediation Plan

Task 4 Instructions

1. For each finding, propose a corrective action
2. Prioritize actions based on risk and effort
3. Create a timeline for implementation (30, 60, 90 days)

4.5 Task 5: Final Audit Report

Task 5 Instructions

1. Write a comprehensive audit report
2. Include executive summary, scope, methodology, findings, recommendations, and conclusion

5 Deliverables

You must submit a professional audit report containing:

1. **Executive Summary** (key findings, overall compliance rating)
2. **Scope and Objectives**
3. **Audit Methodology**
4. **Detailed Findings** (table with finding, framework reference, risk level, evidence)
5. **Recommendations and Remediation Plan**
6. **Conclusion**
7. **Appendices** (audit checklist, interview notes, evidence)

6 Evaluation Rubric

Criteria	Weight	Description
Framework Understanding	15%	Accurate understanding of chosen framework's requirements
Gap Identification	25%	Comprehensive identification of gaps and non-compliance
Evidence Collection	15%	Use of evidence to support findings
Recommendations	20%	Feasible, prioritized, and actionable recommendations
Report Quality	15%	Professional structure, clarity, and grammar
Critical Thinking	10%	Insightful analysis and risk-based prioritization

7 Submission Guidelines

Submission Requirements

- Submit a single PDF file via the course platform
- File name: `Project5_ComplianceAudit_YourName.pdf`
- Use a formal report structure with title page, TOC, and sections
- Include a list of references (regulatory texts, NIST, etc.)

8 Due Date and Late Policy

Important Deadlines

- **Due Date:** _____ (Week 14)
- **Late Policy:** Submissions will be penalized 10% per day
- **Extensions:** Must be requested at least 48 hours in advance

9 Resources

- Framework summaries (GDPR, HIPAA, PCI DSS, SOX) provided in the course
- NIST SP 800-53 and NIST SP 800-30
- Audit checklists and templates
- Textbook Chapters 4, 8, 9